SIMATS ENGINEERING
Engineer to Excel

SIMATS
Saveetha Institute of Medical And Technical Sciences
(Declared as Deemed to be University under Section 3 of UGC Act 1956)

ASSESSMENT TOOL II- ASSIGNMENT

COURSE CODE: ITA14 **COURSE NAME: Ethical Hacking**

COURSE OUTCOME COVERED

CO1: Apply the principle of the foundational concepts of ethical hacking, including types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

ASSIGNMENTS QUESTIONS

1. A company hires you to test its network but gives you only a one-line email authorization with no defined scope. Halfway through testing, you discover a critical vulnerability in a system that wasn't mentioned in the email. Do you exploit it to prove impact? Justify your answer using ethical hacking principles.
2. You are conducting a penetration test and discover that the client's production database contains real customer financial data. Your test plan calls for exploiting a SQL injection vulnerability. How do you proceed without causing harm, and what precautions should have been taken before the engagement began?
3. During a black-box penetration test, you accidentally trigger a denial-of-service condition on a live production server, causing an outage. Walk through what you should have done to prevent this and what your responsibility is now.
4. A client asks you to test their systems but insists you not inform their IT department, wanting to test the team's real-world detection capability. What ethical and practical risks does this create, and how would you structure the engagement to protect yourself?
5. You're asked to perform a "red team" exercise versus a "vulnerability assessment." Using a real-world scenario of a bank wanting to test physical and digital security, explain how your approach, ethics, and rules of engagement would differ between the two.

Code of Conduct: (192371082)

I Sana Fathima M *(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.*

Rubrics

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Problem Context	20	Clearly understands the problem and accurately identifies all data-handling requirements and operations	Good understanding with minor gaps	Basic understanding; some requirements unclear	Poor understanding or misinterpretation of the problem
Application of Concepts	30	Accurately applies appropriate data structures and algorithms to solve complex problems	Applies relevant concepts correctly with minor errors	Applies basic concepts with limited accuracy	Fails to apply appropriate concepts
Problem-Solving Approach	20	Logical, well-structured, and efficient approach	Mostly logical approach with minor gaps	Basic approach with some inconsistencies	Illogical or unclear approach
Accuracy of Solution	20	Completely correct code, output and complexity analysis with proper justification	Mostly correct with minor errors	Partially correct solution	Incorrect or incomplete solution
Clarity	10	Clear, well-organized, and properly explained solution	Understandable with minor clarity issues	Limited clarity and explanation	Poorly presented and difficult to understand

Fathima
192371082.

ITA1405 ETHICAL HACKING

CO1 - AT3

A Company hires you to take test its network but gives you only a one line email authorization with no defined scope. Halfway through testing, you discover a critical vulnerability in a system that wasn't mentioned in the email. Do you exploit it to prove impact? justify your answer using ethical hacking principles.

To obtain permission : Contact the client and request written authorization for the before testing the newly discovered system

Follow the Scope : Test only the systems, IP addresses, and activities exploity approved by client.

Avoid exploitation : Exploiting the vulnerability Could Cause data loss, service, disruption, or the Unauthorized access.

Report responsibly : Inform the client about the vulnerability

Protect Customer Data :-

Never copy, disclose, or modify financial information unnecessarily.

Define rules beforehand :-

Obtain written authorization specifying the scope, permitted the techniques, testing schedule, and prohibited activities.

Prepare Safeguards :-

Establish backups, monitoring, emergency contacts, rollback procedures, and a stop testing protocol.

Report the Vulnerability :-

Document the evidence risk level, and suitable remediation, such as parameterized queries and input validation.

Conclusion :- Testing must verify security weaknesses while protecting customer privacy, data integrity, and service availability

• During a black box penetration test, you accidentally trigger a denial of Service condition on a live production server, Causing an outage. Walk through What you should have done to prevent this and What your responsibility is now.

A denial of Service (DOS) condition When a system becomes unavailable because it receives excessive requests or consumes too many resources.

Preventive Measures :-

→ Define testing limits : Establish clears rules of engagement and identify prohibited activities, by including aggressive load testing.

→ Use a test environment : Test potentially disruptive techniques on a stage system whenever Possible.

→ Monitor System performance : Observe CPU Usage, Memory Consumption, network Traffic and response times during testing

Set Emergency Procedures

Agree on stop conditions, escalation contacts, and recovery steps before beginning.

Responsibilities after Outage :-

→ Immediately stop all testing activities that may be contributing to the outage.

→ Notify Clients' IT and the security teams without Delay.

→ Assist authorized personnel in investigating & restoring the service.

→ Preserve relevant logs & document the incident accurately.

→ Submit an incident report explaining the cause, impact, and preventive Measures.

Ethical hackers must minimize & take immediate responsibility for reporting & testing

A client asks you to test their systems but insists you not inform their IT department, wanting to test the team's real world detection capability. What ethical & practical risk does this create, & how would you structure engangement to protect yourself ?

Testing without informing the IT department is similar to a covert penetration test. It can evaluate the Organization's ability to detect suspicious activities, but it creates legal, operational, & ethical risks.

Risks Involved :

→ False Alarms
→ Service Disruption
→ legal Issues
→ Incident escalation
→ Lack of Coordination.

Obtain written authorization from an authorized management representative.

→ Define scope, permitted techniques

detection, and emergency stop the condition.

→ Keep a designated senior contact or independent coordinator informed, even if the operational security team remains unaware.

→ Establish an emergency the communication channel and clear incident handling procedures.

→ Document all activities and provide a final report comparing test team's actions with security team's detection response.

Conclusion :-

Convert testing should be conducted only with the explicit authorization, the rules of engangement, controlled safeguards, and the that protects the organization and the tester you're asked to perform a "Red team" exercise versus a "Vulnerability assessments". Using a real-world scaneria of banking engagement would differ between two.

A vulnerability assessment identifies and evaluates security weaknesses, whereas a red team exercise simulates realistic attacks to test an organization's overall detection & response the capabilities.

Ethical Consideration :-

→ Obtain written authorization from the bank's authorized management.

→ Define the permitted the digital and physical testing the boundaries.

→ Never Access or Transfer real customer funds or expose confidential financial date.

→ Use Safe Simulations for physical access attempts and social engineering.